



CSPM BEST PRACTICES CHEAT SHEET

Fix the cloud settings that invite a breach

Do's and don'ts for six CSPM practices across AWS, Azure and GCP, with a gap check and the AccuKnox setup page for each gap.

Cloud incidents are common, and fixes take **days**

A public bucket, an open port or an old access key gives an attacker a way in with no exploit at all. Most teams already had a cloud incident last year, and most of them needed more than a day to close it.

65%

of organizations had a cloud security incident in the past year.

Check Point, 2025 Cloud Security Report. [checkpoint.com](https://www.checkpoint.com)

9%

of publicly accessible cloud storage holds sensitive data, and 97% of that data is restricted or confidential.

Tenable, Cloud Security Risk Report 2025. [tenable.com](https://www.tenable.com)

62%

of organizations took more than 24 hours to remediate a breach. Only 6% remediated within the first hour.

Check Point, 2025 Cloud Security Report. [checkpoint.com](https://www.checkpoint.com)

Four reasons cloud posture slips

Each cause below has a matching practice later in this guide.



Accounts multiply faster than anyone lists them

At least 84% of organizations use more than one AWS account. A team opens a new account in minutes, and nobody scans it until someone adds it to a list.



Alerts arrive faster than teams can triage them

More than half of organizations face nearly 500 cloud alerts a day. A queue sorted by count hides the one public database inside it.



Risk hides in combinations of findings

29% of organizations run a workload that is publicly exposed, critically vulnerable and highly privileged. Each finding alone looks moderate, so a severity sort misses the combination.



Settings change after the last review

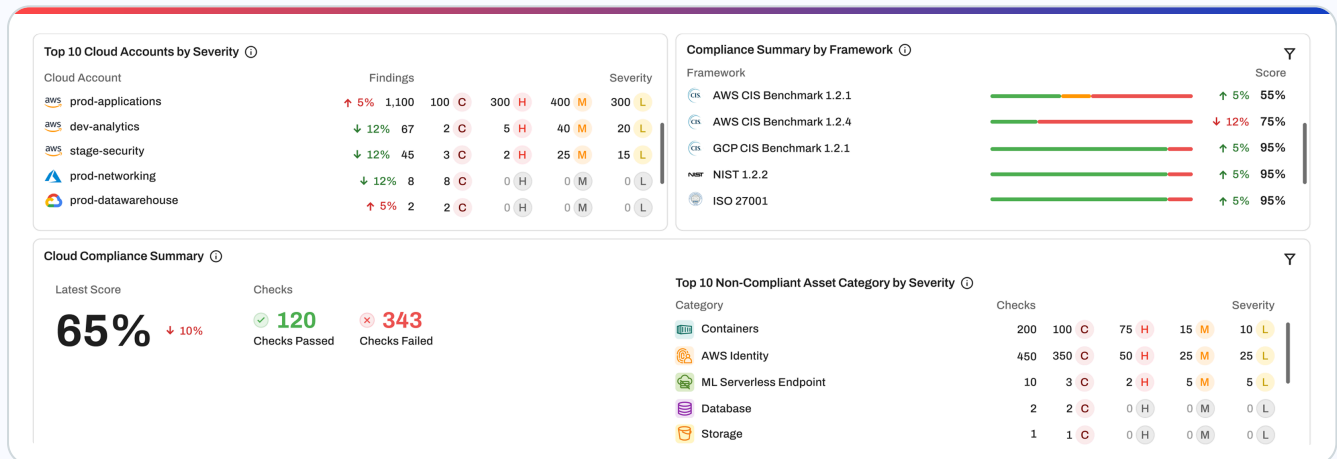
The Cloud Security Alliance ranks misconfiguration and inadequate change control as the first of its 11 top cloud threats. A bucket you secured last month can turn public again today.

Sources. Datadog, [State of Cloud Security 2025](#). Check Point, [2025 Cloud Security Report](#). Tenable, [Cloud Security Risk Report 2025](#). CSA, [Top Threats to Cloud Computing 2024](#).

Start here

Six practices take a finding from found to fixed

Start with a complete inventory, because every later practice scores only the accounts you onboarded. Then rank, map, assign and recheck.

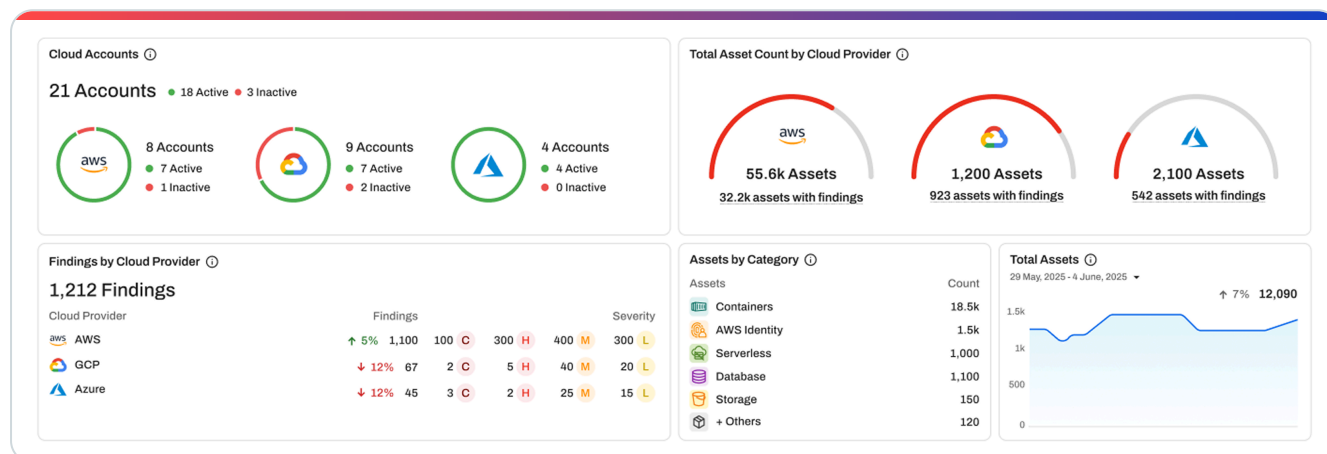


Cloud Findings dashboard in AccuKnox CSPM. help.accuknox.com/use-cases/cspm/

- | | | | | | |
|----|---|----|----|--|----|
| 01 | Inventory every account
Onboard at the organization level | 05 | 04 | Map checks to frameworks
Score against the controls you report | 08 |
| 02 | Fix by risk, not by count
Work critical exposure first | 06 | 05 | Automate tickets
Give every critical finding an owner | 09 |
| 03 | Read findings in context
Use the Security Graph | 07 | 06 | Catch drift
Scan on a schedule against a baseline | 10 |

Put every cloud account in **one inventory**

AccuKnox CSPM scans AWS, Azure and GCP through read only cloud APIs, with no agent, and lists every asset by category.



Accounts and assets per cloud provider. help.accuknox.com/use-cases/asset-inventory/

DO

- Onboard the AWS Organization root or your Azure management groups, so new accounts join the scan.
- Connect a standalone AWS account with STS Assume Role and an External ID, so no access keys are stored.
- Review **Inventory > Cloud Assets** in the list view and the hierarchy view after each scan.
- Label cloud accounts by owner and environment, so each finding reaches the right team.

DON'T

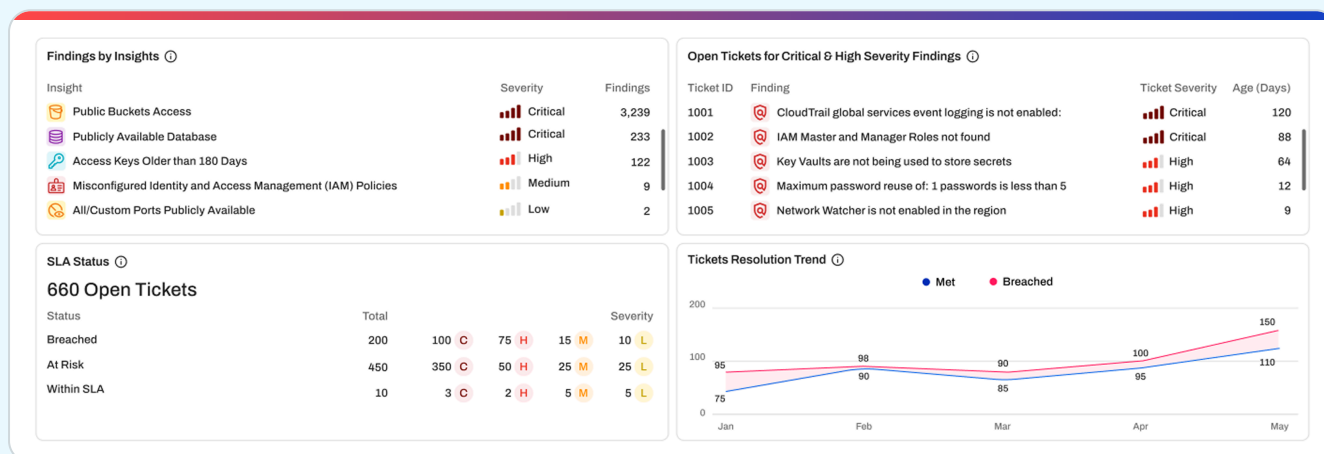
- Don't track cloud accounts in a spreadsheet. A new account stays unscanned until someone adds a row.
- Don't onboard only production. Dev and sandbox accounts hold public buckets and old keys too.
- Don't give the scanner write access. On AWS, CSPM needs ReadOnlyAccess and SecurityAudit.

HOW ACCUKNOX CLOSES THE GAP

AWS Organization onboarding runs a CloudFormation StackSet and can connect new accounts automatically. On Azure, new subscriptions under an onboarded management group are fetched and scanned. [Onboard an AWS Organization](#)

Fix misconfigurations by risk, not by count

One public bucket outweighs a thousand low findings. Sort by risk factor and work the critical rows first.



Findings by insight, open critical tickets and SLA status. help.accuknox.com/how-to/findings-lifecycle/

DO

- Filter **Issues > Findings** by Risk Factor Critical and Status Active, and start there.
- Work the exposure insights first, such as public buckets, public databases and access keys older than 180 days.
- Switch off checks that do not apply to an account in **Settings > Checks Management**.
- Change a check's severity where your context differs, and track SLA status per severity.

DON'T

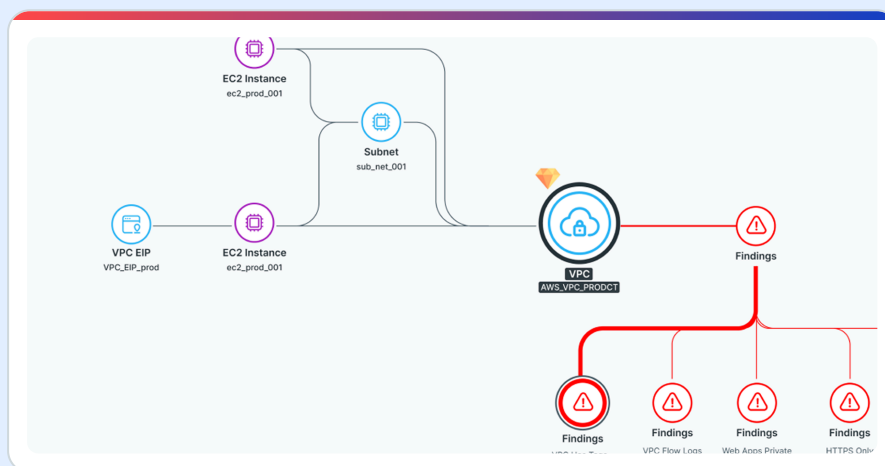
- Don't measure progress by total finding count. One critical exposure outweighs hundreds of low findings.
- Don't ignore a noisy check everywhere. Disable it per account, so findings, compliance and reports stay consistent.
- Don't mark findings Fixed by hand to clear the queue. Let the next scans confirm the fix.

HOW ACCUKNOX CLOSSES THE GAP

A change in Checks Management follows the check into the Findings page, the Compliance page and CSPM reports, for AWS, Azure and GCP. [Read about Checks Management](#)

Read each finding with what it can reach

Security Graph draws each asset with its network path, its IAM identities and the findings on every node.



Security Graph for an AWS asset. help.accuknox.com/getting-started/3.6-release/

DO

- Open **Inventory > Cloud Assets**, pick an asset and open the **Security Graph** tab to see its blast radius.
- Fix first where an Internet node connects to an instance that carries an IAM role.
- Open the graph on a finding to see whether the misconfiguration is isolated or spread across the estate.
- Use the node badges to spot major issues, such as public exposure with logging off.

DON'T

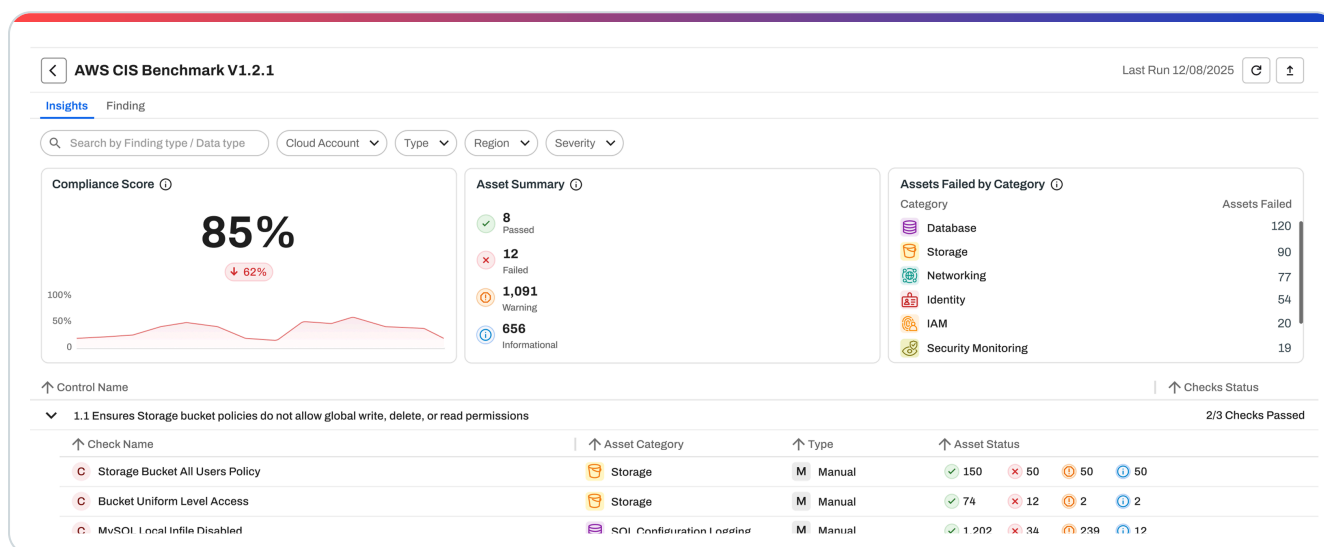
- Don't rank a finding by its own severity alone. A medium finding on an exposed, privileged instance opens an attack path.
- Don't fix one bucket when the same finding sits on twenty. The findings graph shows the rest.
- Don't expect a graph for a new account before its first scan completes.

HOW ACCUKNOX CLOSES THE GAP

Security Graph is on by default for cloud findings on AWS, Azure and GCP, with nothing to configure. Click a node to open its findings inline. [Read the Security Graph notes](#)

Map every check to the frameworks you report on

More than 1,000 built in checks map to over 30 compliance programs, from CIS Benchmarks to PCI, HIPAA, SOC 2 and NIST.



AWS CIS Benchmark score and checks per control. help.accuknox.com/use-cases/compliance/

DO

- Activate the frameworks you report on, including the CIS Benchmark version your auditor uses.
- Read each sub control's pass percentage, then open its failing checks in **Detailed View**.
- Filter failing checks by cloud account, region and severity, and assign each fix to an owner.
- Fix the check that maps to the most controls first. Each finding lists every framework it touches.

DON'T

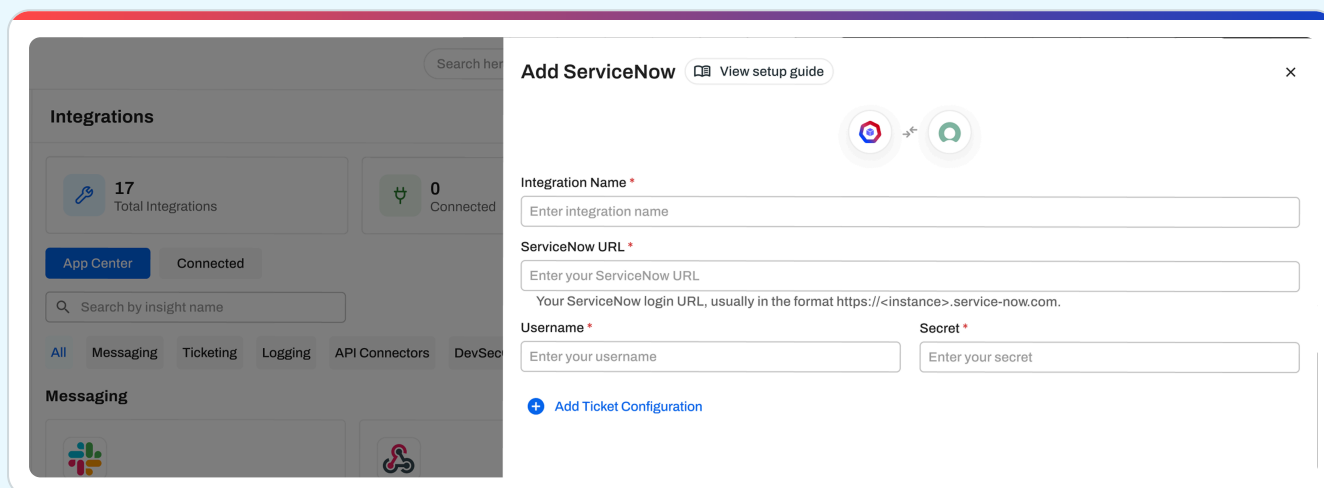
- Don't wait for audit season to look at the score. Scans run on a schedule.
- Don't compare scores across CIS versions. AWS CIS v1.5.0 and v2.0.0 hold different checks.
- Don't read a high score as the full picture. Review the checks you switched off every quarter.

HOW ACCUKNOX CLOSSES THE GAP

The score for each sub control is passed checks divided by passed, failed, warning and not available checks. [View your compliance posture](#)

Send every critical finding to an owner

The Rule Engine turns matching findings into Jira, ServiceNow, Freshservice or ConnectWise tickets.



Adding a ServiceNow ticketing integration. help.accuknox.com/integrations/servicenow/

DO

- Connect your ticketing tool in **Settings > Integrations**, then add a ticket configuration.
- Create a rule in **Issues > Findings > Rule Engine** with conditions and the Create Ticket action.
- Set a Parent field, such as Asset Name or Location, so new findings join one parent ticket per group.
- Open the Solution tab or Ask AI on a finding for remediation steps and code snippets.

DON'T

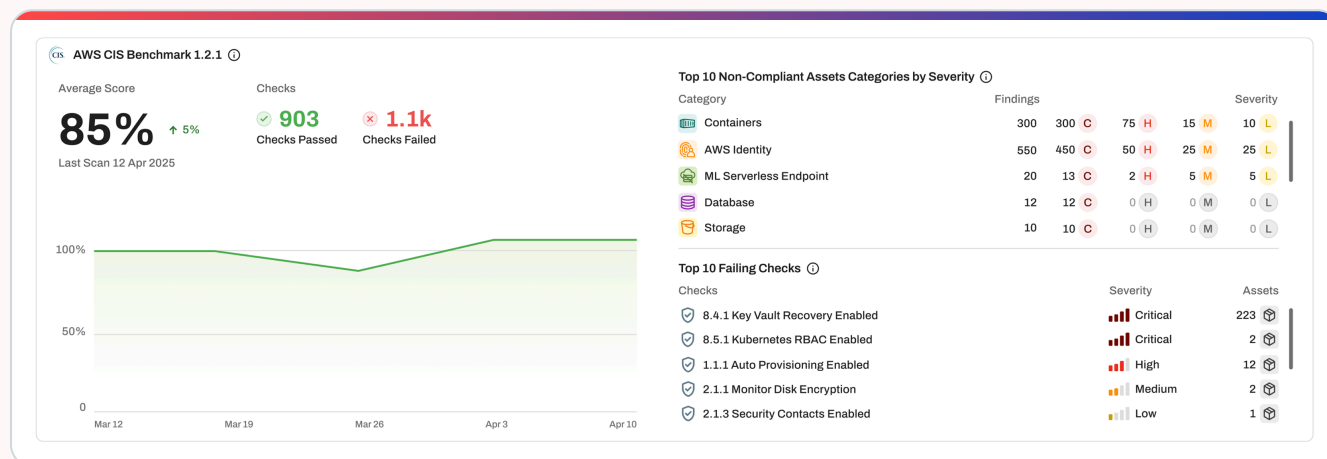
- Don't raise one ticket per finding by hand. A flat list of tickets buries the critical ones.
- Don't close a ticket on a promise. The finding moves to Fixed only after the scans confirm it.
- Don't forget rule expiry. Each rule has an expiration date, so review it when it lapses.

HOW ACCUKNOX CLOSSES THE GAP

A finding moves from Active to Waiting for Verification to Fixed on scan results, and AccuKnox closes the linked ticket. [Automate tickets with the Rule Engine](#)

Scan on a schedule and catch **drift** early

A secure setting can change tomorrow. Scheduled scans compare each resource with its baseline and flag the change.



Compliance score trend and top failing checks. help.accuknox.com/use-cases/cloud-misconfigurations/

DO

- Group your critical assets and apply a baseline, so each scan reports any deviation from it.
- Add Monitors to critical assets, such as S3 buckets and bastion hosts, to alert on a configuration change.
- Watch the compliance score trend per framework and investigate every drop.
- Open **Status Logs** on a finding to see who changed its status and when.

DON'T

- Don't scan once at onboarding and stop. Posture on day one says little about day ninety.
- Don't treat a finding that returns after a fix as new. Find the change that brought it back.
- Don't fix drift only in the console. Fix the template that built the resource, or the setting reverts.

HOW ACCUKNOX CLOSSES THE GAP

AccuKnox scans onboarded accounts on a scheduled interval, and applies baseline conformance to asset groups for drift detection. [Set up drift detection](#)

Find your gap, then take the first step

Read each row. Where the gap is true for you, take the first step this week.

IF THIS IS TRUE	ACCUKNOX CAPABILITY	FIRST STEP
Nobody can list every cloud account and asset	Asset Inventory and organization onboarding	Onboard your AWS Organization or Azure management groups
The team works findings in the order they arrived	Risk Factor filters and Checks Management	Filter Active findings to Critical and switch off checks that do not apply
Nobody knows which exposed instance holds a privileged role	Security Graph	Open the Security Graph tab on your internet facing assets
Audit prep takes weeks of screenshots	Compliance programs and CSPM reports	Activate your frameworks and read the score per sub control
Findings sit on a dashboard that nobody owns	Rule Engine and ticketing integrations	Connect Jira or ServiceNow and add a Create Ticket rule
A fixed setting quietly changes back	Baselines and Monitors	Group critical assets, apply a baseline and add Monitors

See your cloud posture in one console

Book a demo and onboard one AWS, Azure or GCP account. The first scan shows your inventory, your critical findings and your compliance score.

[Book a demo](#)[Read the CSPM docs](#)

2026

AccuKnox is featured in the KuppingerCole CNAPP Leadership Compass, which cites attack path analysis and unified risk correlation.

Source. accuknox.com/analyst-recognition

2

Frost & Sullivan Best Practices recognitions in 2026, one global and one for Asia Pacific.